PRUEBA DE PENETRACIÓN - SPIKA TECH

INFORMACIÓN GENERAL

Nombre del Proyecto: Evaluación de Seguridad Integral Spika Tech

Fecha programada: 15/04/2025

Tipo de prueba: Semestral generalizada

Autorizado por: Jaime de Castro

1. ALCANCE Y OBJETIVOS

1.1 Alcance

- Sitio web corporativo y aplicaciones web

1.2 Objetivos

- Identificar vulnerabilidades en la infraestructura tecnológica
- Evaluar la eficacia de los controles de seguridad existentes
- Verificar el cumplimiento con ISO 27001
- Determinar posibles vectores de ataque que puedan comprometer datos sensibles
- Proporcionar recomendaciones accionables para la remediación

2. METODOLOGÍA Y HERRAMIENTAS

2.1 Marcos de Referencia

- OWASP Testing Guide para aplicaciones web
- Cloud Security Alliance para entornos Firebase/Google Cloud
- NIST SP 800-115 para procedimientos generales

2.2 Herramientas a utilizar

- Seguridad Web: OWASP ZAP(ZAProxy)
- Seguridad en la Nube: ScoutSuite
- Seguridad de Red: Nmap, OpenVAS

3. PLAN DE PRUEBAS DETALLADO

3.1 Fase de Preparación

- Notificado personal relevante: jefe de ciberseguridad y administrador de sistemas
- Dimensionamiento de la infraestructura digital de Spika Tech: estudio de dominios y endpoints
- Obtención de cuenta de google Cloud con capacidad de lectura
- Cuenta de OVH pendiente

SPIKA TECH, S.L., with registered office at c/ Alcalá de Guadaira, nº 6, 6ºA Derecha, 28018 MADRID, with Tax Identification Code B87386900, registered in the Mercantile Register of Madrid, in volume 33.500, Folio 200, Page M-603059, Entry. 1, hereinafter THE OWNER.

empresa innovadora de base tecnológica reconocida por ANCES

Funded by the European Union

3.2 Pruebas del Sitio Web

- Escaneo automatizado con OWASP ZAP
- Verificación de gestión de sesiones y autenticación
- Análisis de configuración de seguridad

4. Hallazgos y vulnerabilidades

Escaneo de dominios pertinentes asociados a *.spikatech.com:

Subdominio	IP
spikatech.com	37.59.203.111
www.spikatech.com	37.59.203.111
compasstest.spikatech.com	37.59.203.111
memoria-2017.spikatech.com	37.59.203.111
mqtt.spikatech.com	37.59.203.111
www.mqtt.spikatech.com	37.59.203.111
itserver.spikatech.com	193.147.50.21
visualcardiopipeline.spikatech.com	34.32.227.118
visualcardiopipelineprod.spikatech.com	34.107.152.59
itilapplication.spikatech.com	87.98.231.18
www.itilapplication.spikatech.com	87.98.231.18

spikatech.com

Escaneo nmap -A

| ssl-cert: Subject: commonName=spikatech.com

| Subject Alternative Name: DNS:compasstest.spikatech.com, DNS:memoria-2017.spikatech.com, DNS:mqtt.spikatech.com, DNS:spikatech.com, DNS:www.mqtt.spikatech.com, DNS:www.spikatech.com

```
| Issuer: commonName=E5/organizationName=Let's Encrypt/countryName=US
| Public Key type: ec
| Public Key bits: 256
| Signature Algorithm: ecdsa-with-SHA384
| Not valid before: 2025-03-27T21:22:03
| Not valid after:  2025-06-25T21:22:02
| MD5:   d5d9dfdf68e892874aa3f19ddefed2ac
|_SHA-1: c01650db8a8da1cf138d356ae0d994dea6741082
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_ssl-date: TLS randomness does not represent time
|_http-server-header: OVHcloud
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 404 Not Found
|     Date: Wed, 16 Apr 2025 08:28:53 GMT
|     Content-Type: text/html; charset=utf8
|     Content-Length: 4959
|     Connection: close
|     X-OVH-Webhosting-Id: 6522b6e2d6cb8f8dba84ece61b3b00d0
|     pragma: no-cache
|     cache-control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
|     Server: OVHcloud
|     <html xml:lang="en-EN" lang="en-EN">
|     <head>
|     <title>Site not installed - OVHcloud</title>
|     <meta name="viewport" content="width=device-width">
|     <meta http-equiv="refresh" content="90">
|     <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
|     <meta http-equiv="Content-Language" content="en-EN">
|     <meta name="robots" content="noindex, nofollow">
|     <meta name="description" qtlid="283606" content="Site not installed">
|     <meta http-equiv="cache-control" content="no-cache">
|     <meta http-equiv="pragma" content="
|   HTTPOptions:
```

```
|     HTTP/1.1 404 Not Found
|     Date: Wed, 16 Apr 2025 08:28:54 GMT
|     Content-Type: text/html; charset=utf8
|     Content-Length: 4959
|     Connection: close
|     X-OVH-Webhosting-Id: 8b3c31067e8adb08300329bce64bfef9
|     pragma: no-cache
|     cache-control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
|     Server: OVHcloud
|     <html xml:lang="en-EN" lang="en-EN">
|     <head>
|     <title>Site not installed - OVHcloud</title>
|     <meta name="viewport" content="width=device-width">
|     <meta http-equiv="refresh" content="90">
|     <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
|     <meta http-equiv="Content-Language" content="en-EN">
|     <meta name="robots" content="noindex, nofollow">
|     <meta name="description" qtlid="283606" content="Site not installed">
|     <meta http-equiv="cache-control" content="no-cache">
|_    <meta http-equiv="pragma" content="
|_http-title: Did not follow redirect to https://www.spikatech.com/
```

Configuración de web incorrecta, acceso a directorios raíz web expuestos:

Index of /

Name	Last modified	Size	Description
.bash_logout	2016-05-09 13:15	24	
.bash_profile	2016-05-09 13:15	236	
.bashrc	2016-05-09 13:15	131	
compasstest/	2018-01-16 10:00	-	
itilapplication/	2018-01-09 12:58	-	
memorias/	2018-01-24 10:25	-	
www/	2021-06-30 12:26	-	

Conclusión: Sitio web con fallos de configuración y dominio raíz expuesto. Securizar instalación en hosting OVH

itilapplication.spikatech.com

Escaneo nmap:

PORT STATE SERVICE

80/tcp open http

110/tcp open pop3

113/tcp open ident

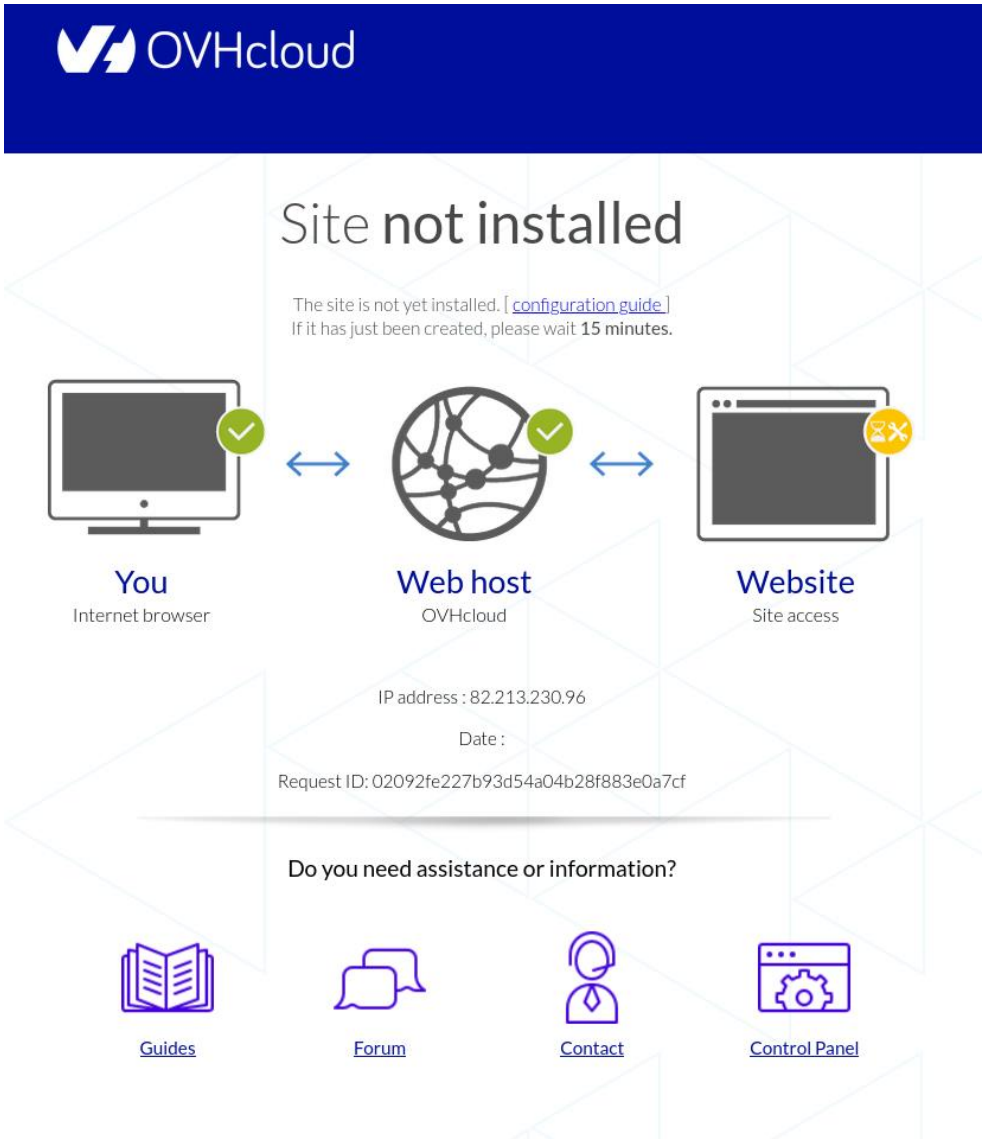
443/tcp open https

554/tcp open rtsp

3389/tcp open ms-wbt-server

8888/tcp open sun-answerbook

Conclusión: sitio web obsoleto y sin configurar, eliminar registro DNS



OWASP ZAP (Informe generado en ANEXO I)

Vulnerability	Severity
Vulnerable JS Library: pdf.js 2.5.207	High
Absence of Anti-CSRF Tokens	Medium
Secure Pages Include Mixed Content (Including Scripts)	Medium
Missing Anti-clickjacking Header	Medium
Content Security Policy (CSP) Header Not Set	Medium
X-Content-Type-Options Header Missing	Low
Cross-Domain JavaScript Source File Inclusion	Low
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low

Cookie No HttpOnly Flag	Low
Strict-Transport-Security Header Not Set	Low
Cookie without SameSite Attribute	Low

OpenVAS (Informe generado en ANEXO II)

Vulnerability	Severity
WordPress Contact Form 7 Plugin < 5.3.2 RCE	Critical
WordPress Contact Form 7 Plugin < 5.3.2 RCE	Critical
WordPress Shortcodes Ultimate Plugin < 5.12.1	High
WordPress Shortcodes Ultimate Plugin < 5.12.1	High
WordPress Popup Maker Plugin < 1.18.0	High
WordPress Popup Maker Plugin < 1.18.0	High
Missing 'HttpOnly' Cookie Attribute (HTTP)	Medium
Missing 'HttpOnly' Cookie Attribute (HTTP)	Medium
WordPress Shortcodes Ultimate Plugin < 5.10.2 XSS Vulnerability	Medium
WordPress Shortcodes Ultimate Plugin < 5.10.2 XSS Vulnerability	Medium
WordPress Popup Maker Plugin < 1.16.5 XSS Vulnerability	Medium
WordPress Popup Maker Plugin < 1.16.9 Multiple XSS Vulnerabilities	Medium
WordPress Popup Maker Plugin < 1.16.11 XSS Vulnerability	Medium
WordPress Popup Maker Plugin < 1.16.5 XSS Vulnerability	Medium
WordPress Popup Maker Plugin < 1.16.11 XSS Vulnerability	Medium
WordPress Popup Maker Plugin < 1.16.9 Multiple XSS Vulnerabilities	Medium
WordPress Shortcodes Ultimate Plugin < 5.12.8 Multiple Information Disclosure vulnerabilities	Medium
WordPress Shortcodes Ultimate Plugin < 5.12.8 Multiple Information Disclosure vulnerabilities	Medium
WordPress ExactMetrics Plugin < 7.12.1 XSS Vulnerability	Medium
WordPress ExactMetrics Plugin < 7.12.1 XSS Vulnerability	Medium
WordPress MC4WP Plugin < 4.8.7 XSS Vulnerability	Medium
WordPress MC4WP Plugin < 4.8.7 XSS Vulnerability	Medium
WordPress ExactMetrics Plugin < 7.14.2 XSS Vulnerability	Medium
WordPress ExactMetrics Plugin < 7.14.2 XSS Vulnerability	Medium
WordPress Shortcodes Ultimate Plugin < 7.0.0 Multiple Vulnerabilities	Medium
WordPress Shortcodes Ultimate Plugin < 7.0.0 Multiple Vulnerabilities	Medium
WordPress < 6.5 Private Information Exposure Vulnerability	Medium

WordPress < 6.5 Private Information Exposure Vulnerability	Medium
WordPress Popup Maker Plugin < 1.18.3 XSS Vulnerability	Medium
WordPress Popup Maker Plugin < 1.18.3 XSS Vulnerability	Medium
WordPress Shortcodes Ultimate Plugin < 7.0.4 - Contributor+ Stored XSS Vulnerability	Medium
WordPress Shortcodes Ultimate Plugin < 7.0.5 - Contributor+ Stored XSS Vulnerability	Medium
WordPress Shortcodes Ultimate Plugin < 7.1.3 - Contributor+ Stored XSS Vulnerability	Medium
WordPress Shortcodes Ultimate Plugin < 7.0.4 - Contributor+ Stored XSS Vulnerability	Medium
WordPress Shortcodes Ultimate Plugin < 7.0.5 - Contributor+ Stored XSS Vulnerability	Medium
WordPress Shortcodes Ultimate Plugin < 7.1.3 - Contributor+ Stored XSS Vulnerability	Medium
ICMP Timestamp Reply Information Disclosure	Low